Notes about network forensics

Digital Forensics and Biometrics 2024/2025 – Simone Milani

Copyright notice: All rights reserved. The educational material available on this platform is for the personal and exclusive use of the students and is covered by copyright. Any further use, in whole or in part, of the teaching material, including the reproduction, re-elaboration, diffusion and distribution of its contents by any means of communication, including technological platforms, software supports or telematic networks, is strictly prohibited, without express authorization by the author. Any improper use may rise in criminal and civil prosecution under the law of April 22, 1941, n. 633 and subsequent amendments (Protection of copyright and other rights related to its use).

Introduction

Network forensics (NF) is the process of monitoring and analyzing computer network traffic. The goal is to gather important information, compile evidence, and/or detect unauthorized intrusions. This branch of forensics plays a crucial role in identifying malicious activities, reconstructing events, and supporting investigations when other data, such as files on hard drives, is unavailable.

Network forensics deals with data that can be:

- **volatile**: network data are often temporary, existing only for a brief period while being transmitted across the network. As a result, they may not be retrievable once it's no longer being transmitted, making real-time monitoring critical.
- **rarely-logged**: network traffic logs are not recorded in detail unless specifically configured to do so. Indeed, logging is often limited for performance reasons due to the high volume and speed of data transmission.

Uses of network forensics

Network forensics is applied in various fields as described in the following.

1. **Security**

- **Intrusion detection**: real-time monitoring of network traffic to detect intrusions or suspicious activities (unauthorized access, unusual patterns, or specific attack signatures).
- **Network evidence**: In cases where other evidence has been compromised or erased (e.g., hard drive is wiped clean), NF allows gathering information about an attack or malicious activity.

2. **Law enforcement investigations**

- **reassembling transferred files**: NF can help law enforcement reassemble files that were transferred across the network.
- **finding keywords and parsing messages**: network traffic can be analyzed parsing messages or data transmissions to find critical pieces of information related to a crime or intrusion.
- **examining packet filters and firewalls**: this can provide insights into what traffic was allowed or blocked, giving clues about the nature of network activity. This examination can help trace the origins of an attack or identify attempts to access restricted areas within a network.
- **examining existing systems**: by analyzing the network activity, investigators can detect anomalies, backdoors, or other signs of compromission.

DE acquisition steps for network forensics

The collection of evidence in network forensics (Network Evidences or Nes) involves several key steps to ensure the integrity and reliability of the information gathered.

1. **Identification**: this initial step involves recognizing and determining if an incident has occurred based on various network indicators, such as unusual traffic patterns or alerts from security systems.

2. **preservation**: In this step, physical and digital evidence is secured and isolated to prevent any alteration. This includes measures like preventing unathorized access, blocking remote connections, etc.

3. **collection and acquisirion**: physical scene is documented, and digital evidence is seized/acquired using standardized methods.

4. **Examination**: detailed, systematic search for evidence related to the network incident. Investigators focus on identifying and discovering relevant data while building detailed documentation that serves as a foundation for further analysis.

5. **Analysis**: determines NE's significance, reconstruct network traffic data, and draw conclusions. This process helps uncover the attack's methodology, origins, and impact based on the patterns and information present in the data.

6. **Presentation**: findings are summarized, and a clear explanation is provided to demonstrate the conclusions drawn from the evidence. This step ensures that the information is understandable and can be used in further investigations or legal proceedings.

7. **Incident response**: a response to the detected attack or intrusion is initiated. This response validates and assesses the incident, addressing vulnerabilities and implementing measures to mitigate further risks or damages.

DE acquisition operates following two different approaches:

- **Catch-it-as-you-can:** involves capturing **all** packets and data as they travel through the network, ensuring a comprehensive record of activities. This approach requires large storage capacity due to the sheer volume of data collected, as every packet is stored for later analysis. Typically, analysis occurs in batch mode, meaning the data is processed and examined after it has been collected, rather than in real-time. This method, which usually operates at the packet level, allows investigators to thoroughly review and reconstruct network events, making it particularly useful for in-depth post-incident analysis.
- **Stop, look, and listen:** processes incoming traffic in real-time. This method requires a fast processor to handle and filter the continuous flow of data efficiently. Instead of storing all packets, only those deemed relevant are saved for further analysis, making it a more selective approach that conserves storage space. Operating primarily at the packet level, this strategy allows for immediate filtering and reaction.

Operations performed by network forensics

Indeed, NF activities enable a set of operations that enable the analysis and protection of network facilities.

1. **Data fusion from multiple sensors**
   Data fusion in network forensics is the process of combining and analyzing data from multiple sources within a network, such as routers, firewalls, intrusion detection systems (IDS), and packet analyzers, to create a comprehensive view of network activities and security events. By integrating information from these diverse tools, data fusion helps identify patterns, detect anomalies, and correlate alerts, enabling more accurate and efficient identification of cyber threats and intrusions. This approach enhances the ability to reconstruct attacks, trace their origins, and develop targeted incident responses.

   Ths possible sources of information can be:
   - *packet analyzers (Wireshark / tcpdump):* tools that capture network traffic at the packet level, providing detailed information about data transfers and protocol usage.
   - *intrusion detection systems (IDS):* generate alerts when they detect suspicious patterns or known attack signatures in the network traffic.
   - *routers, firewalls, log servers:* such elements log network activity, policy violations, and access control information.
   - statistics from protocol analyzers and attack information by observing various threshold values.

   To determine the validity of detected attacks, various combination strategies can be applied (e.g., Dempster-Shafer theory, Bayes' rule, …)

2. **Identification of attack events**
   A large amount of memory and storage is typically required to store and analyze network logs. The network events critical for investigation must be identified efficiently. An effective mechanism must be in place to extract relevant attack features from the collected traces, ensuring that only useful data is stored and examined.

3. **Attack reconstruction**
   Reconstruction of attack events involves piecing together important interactions between intruders and the compromised system. By analyzing logs and network traces, analysts can understand the methodology and steps taken by the attacker. This includes reviewing how the attacker gained access, what actions were performed, and what systems were affected.

4. **Traceback and attribution**
   Identifying the source of malicious packets, known as traceback, is critical in attributing an attack. Techniques used for traceback include:
   - **packet marking**: embedding information in the packets as they pass through network devices;
   - **packet logging**: storing copies or info about packets at key points in the network for later analysis;
   - **Hybrid Approaches**: combining marking and logging techniques in a more comprehensive solution.

5. **Incident response**
   Incident response activities are initiated as soon as alerts are raised. The goal is to act swiftly and discreetly so the attacker remains unaware of the countermeasures. The incident response process includes:

- **detection and validation:** reviewing logs, analyzing the network topology, and examining relevant data to confirm the validity of the alert and understand the nature of the incident.
- **vulnerability identification:** determining the specific vulnerability exploited in the attack, which helps prevent further exploitation of the same vulnerability on other systems.
- **containment and eradication:** developing a containment strategy to isolate the affected systems, eradicating the malicious presence, and ensuring no further damage is done.
- **recovery and investigation:** restoring systems to their normal state and launching a thorough investigation to analyze the attack details, gather evidence, and develop strategies for future prevention.

Such operations can be performed at different levels, which can be summarized as:

- Ethernet analysis
- TCP/IP – Router analysis
- Internet/Server-based analysis
- Wireless analysis

Ethernet forensics

Introduction

Ethernet is the most common way computers in local area networks (LAN), metropolitan area networks (MAN) and wide area networks (WAN). By analyzing the traffic that flows through Ethernet connections, investigators can capture packets of data, identify patterns, and find evidence of unusual behavior, such as unauthorized access or data transfers.

Eavesdropping on Ethernet packets involves using monitoring tools or sniffers to capture and analyze network traffic. In traditional Ethernet setups, a sniffing machine would be placed on the network, while modern Ethernet often uses a switch with a monitoring port for this purpose. As an example, Wireshark is a popular tool for packet sniffing, allowing investigators to inspect various protocols, like the Address Resolution Protocol (ARP), to gather details about network activity.

The uses of sniffers are many, like:

- Analyze network problems
- Detect network intrusion attempts
- Detect network misuse by internal and external users
- Document regulatory compliance by logging all perimeter and endpoint traffic
- Gain information for conducting a network intrusion
- Isolate compromised systems
- Monitor WAN (Wide Area Network) bandwidth utilization
- Monitor overall network usage, including internal and external users and systems
- Monitor data as it moves across the network
- Monitor WAN and endpoint security status

- Gather and report network statistics
- Filter and identify suspicious content in network traffic
- Serve as a primary data source for day-to-day network monitoring and management
- Spy on network users to collect sensitive information, such as login credentials or cookies (depending on encryption)
- Reverse engineer proprietary protocols used on the network
- Debug client/server communications
- Debug network protocol implementations
- Verify network changes, such as adds, moves, and modifications
- Assess the effectiveness of internal controls (firewalls, access controls, web filters, spam filters, and proxies).

Sniffers

How sniffers work

We can distinguish two different ways of sniffing packets on Ethernet links.

Shared Ethernet (old Etherenet structure)
On a shared Ethernet network, a sniffer operates passively by placing the network interface card (NIC) into "promiscuous mode." In this mode, the sniffer captures all Ethernet frames on the network, regardless of the destination MAC address. This allows the machine running the sniffer to monitor and record all traffic, even if it is not directly addressed to it, providing a comprehensive view of the network's activity.

Switched Ethernet
On a switched Ethernet network, sniffers use techniques like ARP spoofing and MAC flooding to capture traffic.

ARP spoofing involves sending fake ARP replies to associate the sniffer's MAC address with the IP address of another device. This diverts the traffic meant for the legitimate device through the sniffer, allowing it to intercept data.
e.g.: Linux command *arpspoof*

MAC flooding overwhelms the switch's MAC address table by sending numerous fake MAC addresses until the table overflows. When this happens, the switch enters fail-open mode, acting like a hub and broadcasting all packets to all connected devices, enabling the sniffer to capture the traffic. Note that this method can degrade network performance and should be used sparingly.
e.g.: Linux command *macof*

How to detect a sniffer running and how to prevent it

Detecting a sniffer on a network can be challenging, but there are several effective methods to identify its presence.

Ping method
Analyzer could send a packet with the IP address of the suspect machine without or with a wrong MAC address. All machines should reject it since MAC does not match. Only the sniffer answers (it does not bother accepting packets with a different MAC address).

ARP method

This verification exploits ARP cache. The analyzer sends a non-broadcast ARP, which is cached by a machine in promiscuous mode. Then, send broadcast IP packet with correct IP but different MAC address. Only machine with correct MAC address from the sniffed ARP frame will respond.

Local host analysis
Hackers may have compromised your terminal and left sniffers. Use ifconfig and analyze the answer on the different ports.

Latency method
Most sniffers do some parsing. Huge amount of data is sent through the network, and during the transmission, the suspect machine can be pinged. In promiscuous mode, it parses all packets and therefore, ping response is delayed. False positives are possible (traffic can be delayed by the network load).

ARP watch
gateway can be spoofed with fake matching in ARP table (Man-In-The-Middle or MITM attack). *arpwatch* can be used to check the ARP cache of a terminal: in case you find duplicates, you may assume that some sniffers compromised the table. With DHCP there can be many false alarms: increase the lDHCP lease time.

Using an IDS
Using some IDS software (e.g., Snort), it is possible to record IP/MAC pairings of packets. Whenever a mismatch is found, it generates an alert.

It is possible to prevent sniffers' action by taking some proper countermeasures, like:

- Use tools that protect the ARP against Man-in-the-Middle (MITM) attacks
- Adopt a cryptographic system to store and transmit data
- Use some sniffing detection tools
- Use stronger security measures on network protocols: t
  These perform real-time checks to identify suspicious activities, such as detecting if a single MAC address is associated with multiple IP addresses, which may indicate ARP spoofing or other malicious behavior. Additionally, network administrators can enhance security by adding MAC addresses of authorized machines permanently to the network, ensuring that only trusted devices can communicate.

Trojans

Trojan malware, specifically in the form of Trojan spyware, can be used as well to eavesdrop information. More specifically, Trojan can monitor and capture data packets transmitted over the network or towards a specific target terminal and force the system to forward data towards attacker's device. These vulnerabilities can be related to insecure protocols, unpatched software, or misconfigured network devices, allowing the Trojan to remain undetected while siphoning sensitive information.

Once installed, a Trojan can take complete control of the infected device, turning it into a "zombie" that the attacker can manipulate remotely without the victim's knowledge.
Trojan spyware specifically focuses on gathering information stealthily. It can collect different types of data, such as:

- **communications**: messages exchanged through email, chat applications, and social media platforms;
- **logs**: recording keystrokes (key logging), which can reveal passwords, usernames, and other sensitive information;
- **voice calls**: intercepting voice calls made through VoIP applications;
- **images and videos**: using device's camera and microphone, the Trojan can record images and videos of the user and their environment, creating a visual record of activities and interactions.

This collection of data allows attackers to create a detailed profile of the victim, gather sensitive or private information (credit card numbers, access to bank accounts, …), forcing the system into illegal activties (e.g., taking part in some cyber attack).

It is important to differentiate between the actions of a Trojan and traditional Man-in-the-Middle (MITM) attacks. In a MITM scenario, the attacker acts as a relay between two communicating parties, intercepting and possibly altering the data being exchanged. However, with a Trojan, the attacker does not merely relay information; they have direct access to the device and can collect data in a more invasive manner. This makes Trojans particularly dangerous, as they can bypass many security measures that might protect against MITM attacks.

How Trojans gain control

Trojans typically gain access to a device through various deceptive methods, including:

- **Malicious links**: Users may inadvertently click on links in emails or messages that lead to the download of Trojan malware. These links often disguise themselves as legitimate content.
- **SMS and phone calls**: Attackers may send malicious SMS messages or make phone calls that prompt users to download and install malicious applications or visit harmful websites.
- **Malicious applications**: Trojans can also be bundled with seemingly benign software, leading users to install them unwittingly. This is particularly common in free or pirated software, where the user is unaware of the risks involved.

TCP/IP-Router forensics

Introduction on routers

Routing is a fundamental process in network communications to manage and direct the flow of data packets across networks. Routers are specialized devices responsible for interconnecting different network segments, enabling communication between various devices and systems. When a packet of data is sent over a network, the router's job is to determine the best path for that packet to reach its destination efficiently. This decision-making process involves examining the destination IP address within the packet and consulting a routing table—a dynamic set of rules and routes that the router uses to choose the most appropriate path.

The routing table contains information about different network paths, including metrics such as hop count, bandwidth, and congestion levels, helping the router evaluate and select the optimal route. Such analysis is seamless across the multiple network segments as routers keeps on forwarding the packet towards its final destination.

Routers also have the capability to select alternative routes if multiple paths exist, allowing for flexibility in case of network failures, congestion, or other disruptions. For example, if one route

becomes unavailable, the router can redirect packets through an alternative path ensuring uninterrupted data transmission. This capability not only enhances the efficiency of the network but also contributes to its reliability and robustness, as it adapts in real-time to changing network conditions.

As a matter of fact, protecting routers is of paramount importance, yet they are often overlooked in security strategies. This fact can be ascribed to different reasons. Indeed, router functionalities often offer quite limited procedures to harden their security level; furthermore, routers are generally slower to receive firmware updates and patches compared to other network devices, leaving them exposed to attacks for extended periods. Note also that few organizations monitor router configurations regularly or adopt stronger secuirty settings as many device are equipped with basic security measures only. In the end, given that there are billions of routers in use worldwide, the scale of potential vulnerabilities is enormous.

Router elements

The sources of information that can be used be listed in the following.

Components:
- ROM
- POST
- IOS
- RAM
- Flash memory
- NVRAM

Ports:
- LAN Ports
- WAN Ports
- Administrative ports
  - -console ports
  - -auxiliary ports

Working modes:
- Setup mode
- User mode
- Privileged mode
- Global configuration mode
- Interface mode

Router attacks

Attackers target routers for various malicious purposes, leveraging a range of techniques to compromise their integrity and functionality. Among the possible hazards, we can mention the following list.

- **reconnaissance:** attackers gather as much information as possible about the network and the devices connected.
- **scanning and enumeration:** actively probe the router to identify vulnerabilities, open ports, and services that could be exploited.
- **gain access:** once vulnerabilities have been identified (e.g., weak passwords, outdated firmware, or misconfigured services), it is possible to gain an unauthorized entry, often at user-level (at the beginning).
- **escalate privileges:** after gaining user-access, attackers could aim at gaining administrative control to manipulate router settings, disable security features, or gain further access to the network.
- **maintaining access:** after bearking into a routing system, the main purpose of an attacker becomes carrying on his/her activties while avoiding being detected. For these reasons, they put into action a set of measures to their digital footprints, such as deleting logs or modifying access records. They might also install backdoors, ensuring they can regain access later even if their original method is patched or discovered.
- **Denial of Service (DoS) attacks**: attackers flood the router with excessive traffic or specially-crafted packets to overload it and put it out-of-service.
- **packet mistreating attacks**: attackers manipulate packets themselves, corrupting or diverting traffic maliciously.
- **routing table poisoning**: router's routing table entries are tampered so that the router sends traffic along incorrect or malicious paths (intercept sensitive data).

- **persistent attacks**: continuously attempt to exploit router vulnerabilities or introduce new methods for access even if the network administrators take corrective measures.

Gathering DE from routers

Considering their crucial role in the network and the amount of volatile data to be logged, acquiring digital evidence from routers is an important step in network forensics. To do so, it is important to follow a chain of steps.

- *connect to the router's console port* using a suitable cable and a laptop equipped with terminal emulation software like PuTTY or Tera Term. This is essential for securely interfacing with the router, especially if remote access is compromised.
- *record the system time (timestamp*) to correlate events and logs across various devices within the network - it is important to identify who is logged onto the router at a specific moment.
- *save configuration file* which can be compared it to baseline or previous versions to identify any unauthorized changes. This imply running show commands on software and firmware version (operating system version, uptime, and serial number), the access control lists (ACLs), the adopted routing protocols, the configuration of interfaces, … All this information allow revealing alterations.
- *record logs* to verify unathorized access
- *reviewing routing tables* since attackers often manipulate them to create malicious static routes that redirect traffic.
- *examining ARP cache*, which could show discrepancies or suspicious entries in the mapping between IP and MAC addresses (they could reveal that attacker has attempted to impersonate another device).
- *copy all volatile data,* like register values and memory.

In the process of collecting/acquiring evidences, please avoid:

- rebooting the router (you will lose volatile data)
- access the router through the network, unless it is not possible to do differently (e.g., a router under the sea).
- run configuration commands, i.e., modifying the existing configuration.
- rely only on persistent information.

Traceback

Characteristics of traceback on routers

Traceback is crucial in many network security operations, especially when dealing with Distributed Denial of Service (DDoS) attacks or detecting spoofed IP addresses.
Indeed, the goal of traceback is identifying the source terminal of a malicious packet or file since attackers often use spoofed IP addresses to mask their true origin.
Techniques such as packet marking, logging, and using hop-by-hop methods help in reconstructing the route taken by a packet.

Traceback task needs to cope with several critical challenges which are realated to dynamic nature of network attacks and can be summarized in the following.

- Attackers can craft and send any packet with spoofed source addresses; this make the use of traditional traceback commands unsuccessful..

- Coordinate attacks may be enacted by multiple offenders working together; thie makes attribution more complex since malicious traffic appears distributed across different sources.
- Attackers may be aware of traceback techniques and could employ countermeasures like packet fragmentation or blending malicious traffic with legitimate streams to evade detection.
- Routers typically have limited processing power and storage capacity. This can be a problem since traceback often requires aggregating and cross-referencing packet logs from multiple routers, which have limited processing power and log storage.
- Despite routers are not frequently compromised, traceback can still be difficult since not all the routers could be supporting traceback utilities (reducing the effectiveness of monitoring).
- Suspicious streams may consist of only a few packets, making it difficult to establish a pattern or collect enough data to accurately identify the source terminal.

In order to overcome such difficulties and enable a reliable source identification for network streams, traceback methodologies needs to satisfy a. set of requirements:

- The traceback functionality should be compatible with existing network protocols, routers and infrastructure; indeed, the addition of alteration of information must not change the normal behavior of network devices.
- Functions on transit routers must be kept simple and minimal.
- They must provide support for incremental implementation, partial deployment and scalability
- In terms of time and resources (processing, bandwidth, memory), the demand must be minimal in order to avoid a decrement in network performances,
- They must identify a source quickly with a few packets.
- They must require a minimal involvement by the Internet Service Provider (ISP), which could not be collaborating.

Traceback strategies for routers

Router traceback strategies can be divided into solutions that involve logging packets at key routers or marking packets with a router ID stap.

When considering *packet logging* roouters, packet information is stored for a later analysis to reconstruct the attack path. To this purpose, we can mention:

- Source Path Isolation Engine (SPIE): it consists in logging packet hashes derived from multiple fields within the packet.
- Autonomous Management Network (AMN): in this case, sensors monitor network traffic and relay information to a central managing device.

As for *packet marking* solutions, router's address (fully or partially) is embedded into the IP packets. Such embedding can be performed following different policies.

- Embedding can take place randomly (Probabilistic Packet Marking, PPM) or deterministically.
- Hash of router's address could be used like in Advanced and Authenticated Packet Marking (AAPM) - 8bit hash - or Algebraic Packet Marking (APM) - 15bit marks, generated by algebraic methods.
- Fast Internet Traceback (FIT) uses a fragment of the hash, the number of fragment and a distance field
- deterministic methods include Deterministic Packet Marking (DPM) and Deterministic Edge Router Marking (DERM), where edge routers mark packets consistently to ensure reliable traceability.

In order to take advantage of both solutions, some hybrid approaches have been designed.

- Distributed Link List Traceback (DLLT): packets are marked and their IP address and packet ID are stored in a table.
- Hierarchical IP Traceback System (HITS): combines marking and logging in a multi-layered approach
- Hybrid Single Packet IP Traceback (HIT)
- Logging and Deterministic Packet Marking (LDPM)

Server forensics

At this analysis level, the forensic investigation examins server's file systems, logs, network connections, and running processes to identify unauthorized access, data breaches, or the execution of malicious code.
For this purpose, several disciplines are combined together, including network analysis, operating system investigation, and application-specific scrutiny. Such integration proves to be necessary in order to establish a clear timeline of events and pinpoint attackers' operations.

Analysts use a variety of tools and techniques to analyze logs (e.g., access, error, and authentication logs), inspect configurations, and correlate network traffic with server activities. Such analysis allows both to determine the root cause or vunerability for an incident and to design new protection and defense strategies.

Server logs may include several information. Including

- Number of visits and number of unique visitors (no repetitions)
- Visit duration and last visits
- Authenticated users, and last authenticated visits
- Days of week and rush hours
- Domains/countries of host's visitors.
- Hosts list
- Number of page views
- Most viewed, entry, and exit pages
- File types
- OS used
- Browsers used
- Robots used
- HTTP referrer
- Search engines, key phrases and keywords used to find the analyzed web site
- HTTP errors
- Some of the log analyzers also report on who is on the site, conversion tracking, visit time and page navigation.

Such information can be stored using different file formats, among which we can mention the **NCSA Common Log Format (CLF).**

NCSA CLF is a standardized logging format widely used by web servers to record HTTP transactions. Developed by the National Center for Supercomputing Applications (NCSA), it provides a simple and consistent structure for logging client requests, making it easier to analyze web traffic and identify patterns.

Example: 127.0.0.1 user-identifier willbyers [30/Aug/2017:10:25:16 -0700] "GET /apache_pb.gif HTTP/1.0" 200 1068

where "**–**" in a field indicates missing data.
In the reported example, we can say that:

0.0.1	is the IP address of the client (remote host) which made the request.
User-identifier	is the RFC 1413 identity of the client.
willbyers	is the user id of the person requesting the document.
[**30/Aug/2017:10:25:16 -0700**]	is the date, time, and time zone that the request was received
"**GET /apache_pb.gif HTTP/1.0**"	is the request line from the client.
200	is the HTTP status code returned to the client. 2xx is a successful response, 3xx a redirection, 4xx a client error, and 5xx a server error.
2326	is the size of the object returned to the client, in bytes

Another format can be **Extended log format (ELF).**

Forensic uses of honeypots

A **honeypot** is a security mechanism designed to detect, deviate/contain, or analyze cyber attacks by simulating a vulnerable system or device. The term "honeypot" can be used very widely referring to a social account, a set of services, a complete operating system, or even an entire network, used to lure potential attackers/external users into interacting with it.
The purpose of a honeypot is not only to contain intruders but also to gather insights about attackers/strategies. Such functionalities can be extended to analytic honeypots like sical media accounts or channels, which can be used to gather information about other users and their interactions. Indeed, honeypots help cybersecurity experts to study attackers' strategies, understand vulnerabilities, and develop better defenses.

As a matter of fact, honeypots possess a set of peculiar features that are listed in the following.

- **They are designed to be compromised**. Honeypots usually emulate systems, softwares or services that are either obsolete or misconfigured, making them appear as soft targets (e.g., unpatched web servers, outdated FTP services, or legacy operating systems that are widely reknown for their weaknesses).
- **They are well monitored and logged all the time.** Every detail of an attacker's activity is recorded (e.g., commands, files accessed, or attempts to gain privileges). Such activity is usually coordinated with network traffic analysis (e.g., using Wireshark), host-based monitoring agents, and system call tracers in order to gain further insights about the attack. Moreover, additional information caming from external IDS and Intrusion Prevention Systems (IPS) could be integrated as well.
- **No essential activties are deplyed on a honeypot system.** Since they serve as decoys designed to draw attacks away from critical components, no important data or essential functionalities are implemented on honeypots. Indeed, their purpose is to shield the real assets diverting malicious activities to fake services or systems. In this way, network manager gain more time to detect and mitigate the threat (while getting imore nformation about it at the same time).
  Some honeypots are dynamic (**honeynets**): a network of honeypots machines/services that are designed in order to offer multiple targets that makes more difficult to distinguish genuine targets from traps. In high-interaction honeypots,

attackers are allowed to move freely within the controlled environment, believing they are gaining access while being constrained within a network sandbox.

Types of honeypots

Honeypots offer different levels of interactions, which lead to the following categorization.

Low-interaction honeypots:
They simulate only a few services and offer minimal interaction. They are easy to implement and update as they gather simple information such as connection attempts, exploit payloads, or scanning techniques (e.g., fake HTTP services). Indeed, they present a lower risk since deep penetration is averted but the probability of engagement and the quality of information gained are lower.

High-interaction honeypots:
They simulate entire operating systems or networks with full functionalities. Such solutions give attackers the freedom to move within the environment, which allows researchers to gather detailed intelligence on advanced attacks. Unfortunately, they require more resources and attention since attackers have more freedom increasing their possibility of breaking in the, real network assets using honeypots as a pivot point if not properly isolated.

Client-side honeypots:
They aim to detect attacks addressing client systems, i.e., they mimic common client behavior, (e.g., web browsing or email fetching), and monitor for attempts to exploit their own vulnerabilities.

Pros and Cons

Among the possible advantages, we can mention that:

- they allow to detect intrusions that might otherwise go unnoticed.
- they allow researchers to study new hacking techniques, malware payloads, and emerging threat vectors.
- diverting attention away from actual assets
- they allow minimizing false positive attack detection: since no legitimate activity should occur within a honeypot, any detected interaction detected is almost certainly malicious (fewer false positives w.r.t. traditional IDS).

Among the possible disadvantages, we can mention that:

- they require constant updates and monitoring to remain effective, i.e., lure attackers by looking like possible targets
- they could potential attack vectors, and therefore, network manager must properly configure them to prevent malicious users from breaking into the real system;
- some jurisdictions may raise legal and ethical questions concerning the privacy of individuals and the legalities of data collection. Honeypot has no value, and therefore, it is not possible to legally claim any damages. Moreover, their use may be challenged as an unfair entrapment.

Wireless forensics

The huge adoption of wireless technologies (e.g., Wi-Fi networks) has placed wireless data as one of the major attack vectors for organizations. Incident handlers and law enforcement have been forced to deal with the complexity associated with these technologies when managing and responding to security incidents.
The wireless forensic (WF) process involves capturing all data moving over the network and analysing network events in order to uncover network anomalies, discover the source of security attacks, and investigate breaches.
When performing wireless forensics, the security analyst must follow the same general principles that apply to computer forensics: identify, preserve and analyse the evidence, in order to impartially report the findings and conclusions.

Technical details and challenges

The main technical challenges associated to wireless forensics are due to the intrinsic nature of radio frequency (RF) communications and the complexity of the physical medium and standards specifications.

Wireless physical frequencies
Wireless data networks divide the frequency spectrum in several channels that can be used to establish multiple non-overlapping communications.
Standard wireless equipment only contains a single radio component; therefore, it is only capable of listening to a specific channel at a given instant. Wireless tools have used a technique called channel hopping to scan the whole frequency spectrum and sample all the different channels, however, using this method the radio is only listening for a few milliseconds in each channel.
When dealing with a single wireless access point, capturing traffic is not a challenge because the access point transmits in a unique channel. However, enterprise and large environments with multiple access points present a challenge for accurate traffic captures. WF tools must be capable of capturing all the traffic from all the wireless networks in a given area when a suspect is located. Therefore, the tools need to listen to all channels simultaneously.

Terminal mobility and roaming
One of the major advantages wireless networks provide is the capability of moving around the wireless network range without losing connection. For large networks, this is mainly accomplished through roaming, a technique to switch from the current access point to the another quickly while sending and receiving data (roaming). Such operations are performed considering the strength of wireless signal.

WF tool need to monitor all the channels to avoid losing portions of the session during roaming. In addition, the location of mobile clients (which could be changing in time), and the forensic examiner could be problematic since only one end of the communication can be collected due to frequency or access point changes.
Collecting data near to the access point could be good, but this could not be a realistic scenario, especially when the network presents multiple access points (the analyst cannot be in all of them at the same time) or when wireless ad-hoc (client to client) networks are used. From a WF perspective this challenge can only be solved by placing multiple traffic capture sensors around the facilities.

Wireless capture

When capturing wireless traffic, it is important to consider its main characteristics, such as frame types, sizes, approximate number of frames and bandwidth requirements.
As an example, IEEE 802.11 specifications define three different types of frames: control, management and data frames. The first two only exist on wireless networks (not in wired networks) and will influence the amount of data captured.

Tips in setting up a WF acquisition

The following list summarizes some best practices and considerations that should be taken into account when instantiating or performing a wireless forensic acquisition of a legal evidence.

- device should have 15 radio components (or cards) to be able to monitor all fourteen 802.11b/g channels and, at the same time, channel hop through the spectrum.
- a GPS (Geographical Positioning System) device can provide accurate timestamps and outdoor location capabilities.
- capture all traffic without applying any capture filter, to not miss any real evidence. If regulations enforce it, filters would be applied to only collect traffic from specific access points or clients only (others can be applied later in the analysis).
- Use a completely passive device, not generating any traffic into the medium (some tools enable a hardware attenuator that reduces or cancels the transmission power, or/and a one-way reception amplifier; his can also be enforced at the software level by placing the wireless cards in monitor mode).
- use high-gain directional or omnidirectional antennas (increase the reachable distance).
- collect additional information about the traffic, such as received signal strength (RSSI), capture device, channel, and other signal/noise quality information, to localize devices.

Example of analysis for network evidence: Intrusion Detection System (IDS)

An example of analysis for a network forensic evidence can be found in Intrusion Detection Systems. An IDS is a network security component designed to identify malicious activity and unauthorized access attempts. IDSs are categorized based on their deployment and monitoring capabilities.

Host-based Intrusion Detection Systems (HIDS) operates on individual terminals and examine system logs, processes, file integrity, or even specific network interfaces.

Network Intrusion Detection Systems (NIDS) operate at the network layer, sniffing network traffic in real time to detect abnormal packets or unusual data flows.

Protocol-based Intrusion Detection Systems (PIDS) concentrate on monitoring traffic related to a specific protocol, like HTTP, to detect protocol-specific threats.

Application Protocol-based Intrusion Detection Systems (APIDS) are designed to protect application-layer protocols, such as SQL, by inspecting application-specific communications.

In the following, we will consider HIDS and NIDS more in detail.

Host-based IDS

Host-based Intrusion Detection system or HIDS are protection systems to detect and report signs of compromise or unauthorized access. Such systems are installed directly on individual computer hosts and could monitor:

- system activities,
- log files,
- incoming network traffic,
- system calls
- audit logs
- error messages

or other signals issued by the Operating System.

Unlike Network Intrusion Detection Systems (NIDS), which focus on identifying attacks within network traffic, HIDS provides deeper visibility by indicating whether those attacks were successful on the host machine.
HIDS can detect locally executed attacks, such as those initiated via physical means like USB devices, out-of-band connections[1], or direct terminal access, which NIDS might not capture since these methods bypass typical network channels.

Among the advantages of HIDS, we can mention the following points.

- They are robust against evasion techniques that exploit network-level vulnerabilities, such as **fragmentation** and **Time-To-Live (TTL) manipulation**.
    - In fragmentation, attackers split malicious packets into multiple chunks, which are then reassembled at the host.
    - manipulating the TTL values, it is possible to shape the statistics of network streams by inserting dummy packets that are going to expire after passing the targeted network sensors.
- effective against attacks that leverage physical access (e.g., through USB)
- capture post-exploitation activities and lateral movements that may go unnoticed in network-only monitoring

Despite this, such monitoring components present some limitations.

- **Maintenance and configuration** of HIDS could be time-consuming and inefficient in environments with several devices as each host must be individually configured, monitored, and updated.
- **Micro view of attacks:** HIDS lack a holistic view of the full neyworkrequired to detect distributed reconnaissance activities, such as **ping sweeps** or **port scans**, targeting multiple systems simultaneously.
- **Host could be compromised: in this eventuality,** network connection could be disabled, preventing the host from sending alerts or notifications to the central management system.
- **Operating system limitations and diversity:** host could support different OS versions or platforms so that HIDS softwares need to be adapted to each environment. This variability can introduce compatibility issues and functional inconsistencies.

[1] *Out-of-band* is a term used to describe any traffic or access that doesn't traverse the public or monitored network (private network, a console connection, or an RS232 serial connection).

Network-based IDS

Network-based Intrusion Detection Systems (NIDS) deploy sensors or probes strategically across the network infrastructure. These sensors actively monitor and capture network traffic, analyzing packets in real-time to detect patterns that match predefined signatures or anomalous profiles. Upon identifying a traffic pattern or signature indicative of malicious activity, the sensor immediately generates an alert to the central management system. Additionally, NIDS sensors can be configured to implement automated response actions, such as blocking the suspicious traffic or terminating the connection, to prevent further unauthorized access or mitigate the attack's impact.

Such system present several advantages.

- They see intrusions from a network perspective. While host-based detection can't detect a ping sweep or a port scan across multiple hosts, network-based IDSs can easily detect such reconnaissance attacks.
- They don't depend on the resources of a host machine and, therefore, won't use valuable network and CPU cycles on mission-critical servers.
- Since there's no software to install, there are no issues with OS compatibility since IDS software runs only on the director and the sensors.

Despite this, we must mention some limitations that have significant consequences on effectiveness and scalability in dynamic network environments.

- **Bandwidth capacity limitations**: NIDS probes must continuously capture, reassemble, and analyze all network traffic in real-time. As network size and traffic volumes grow, NIDS must scale accordingly, which can lead to significant performance bottlenecks or the need for costly hardware upgrades.
- **Vulnerability to packet fragmentation**: attackers may fragment packets to evade detection (they need to be reassembled to analyze payloads) manipulating packet delivery order (e.g., sending fragments from last-to-first) or introducing overlapping fragments, which can confuse the reassembly process.
- **TTL (Time-To-Live) manipulation**: adjusting TTL values alter the routing and lifespan of packets, making it difficult for NIDS to accurately monitor or trace malicious activity. While NIDS can sometimes compensate for such manipulations, these adjustments add complexity to packet analysis.
- **Encryption**: encrypted traffic conceals packet payloads, rendering signature-based detection and content inspection ineffective (these packets can not be read in transit without decryption keys).

IDS trigger mechanism

The trigger mechanism of an Intrusion Detection System (IDS) serves as the pivotal operational core that activates threat detection protocols in response to identified security events within a monitored environment.
IDS can employ either **signature-based** detection, which relies on predefined patterns or signatures of known threats, or **anomaly-based** detection, which establishes a baseline of normal behavior and flags deviations that may indicate malicious activity. When the IDS encounters data that meets the criteria for a trigger—such as a specific sequence of packets that aligns with a known attack vector, or a significant deviation from established user behavior—it activates an alert mechanism.
The effectiveness of the trigger mechanism is contingent on its sensitivity and specificity; thus, careful calibration is essential to minimize false positives while ensuring rapid detection of genuine threats. Moreover, the trigger mechanism must be continuously updated and refined

to adapt to the evolving landscape of cybersecurity threats, incorporating machine learning techniques and real-time intelligence to enhance its detection capabilities.

Misuse Detection (Signature based)

Misuse detection is commonly referred to as signature-based detection. *Misuse detection* requires the use of signature files that identify intrusive activity. The signature files used in misuse detection are analogous to signature files commonly used in virus-scanning software to identify viruses on computer systems.
A *signature file* is a set of rules used to identify common intrusive activity. Highly skilled personnel discovered attacks, patterns, and methods to write signature files to identify them and IDS vendors provide updates to signature files as more attack methods and exploits are discovered (e.g., updates of virus-scanning software).

Among the advantages of an IDS using misuse detection triggers, we can mention:

- Signature files are developed based on **known attack** methods and activities.
- They presents **fewer false positives** compared to anomaly detection, as it identifies known intrusive activities rather than just unusual traffic patterns (outliers). They do not monitor patterns since they look for matches with configured signatures.
- They allow an **immediate network protection** after updating signatures.
- The **signature database** contains descriptions of known intrusive activities, enabling easy management of each signature.
- Administrators can view, enable, or disable individual signatures, providing granular control over the IDS. Different alarm levels and preventive actions can be configured for each signature.
- Moeover, administrators can view signature files to comprehend the conditions that trigger alarms.

It is also worth mentioning a set of disadvantages that need to be compensated with anomaly-based systems.

- **Inability to detect variations on attacks:** unlike anomaly-based systems that dynamically adjust to new threats, signature files remain static, meaning that if an attack does not align with any existing signatures, the IDS sensors will not generate an alert. This predictability allows the intruders to tailor the stream or the operations in order to bypass defenses.
- **Inability to detect new attacks:** prior knowledge of an attack is required meaning that new or undiscovered attacks are often undetectable. The effectiveness of misuse detection relies heavily on keeping the signature database updated.
- **Signature file administration:** Keeping the signature database current with constant updates and applying those updates to all sensors can be a difficult and time-consuming task.
- **Maintaining state data:** sensors in an Intrusion Detection System (IDS) must maintain state data to effectively match activity or traffic against preconfigured signatures since attackers may fragment their packets, necessitating that sensors record and recompile this information to identify matches. As an example, a security administrator might want to be alerted for persistent port scans rather than single instances, making it crucial for the sensor to retain records of scanned ports over time. But sensors have limited storage capacity, causing the loss of important information about the attacks.

Anomaly Detection (Profile based)

These systems analyze computer activity and network traffic looking for anomalies. If an anomaly is found, an alarm is triggered. An anomaly is any deviation or departure from the normal or common order, form, or rule. Because this type of detection is looking for any activity or traffic that isn't normal, the security administrator must first define what is normal activity or traffic. The procedures to build such triggers can be statistical sampling, rule-based, and the adoption of neural networks.

Statistical sampling: alarms are issued in presence of deviations from a defined normal state, which is established through sampling typical activity over a specific timeframe. Normalcy is quantified using statistical measures, such as the average or median w.r.t standard deviations that indicate how much activity diverges from this norm.

Rule-based approach: alarms are generated by triggers that follow rules defining normal user activity; these are created by sampling computer and network activity for a given amount of time.

Build profiles using neural networks: neural network can be used as a model or definition of normal activity. Any activity that doesn't map correctly to the matrix or neural network is considered abnormal and generates an alarm.

Among the advantages of anomaly-based IDS, we can mention:

- The primary advantage of anomaly detection is its independence from preconfigured signatures or known attack patterns. Profiles can leverage artificial intelligence to assess normal activity dynamically. Anomaly detection is better suited to identify previously unknown attacks that deviate from established profiles.
- Intruders cannot predict what will generate an alarm, as they lack access to the detection profiles (unlike signature-based detection).
- User group profiles function like a dynamic signature database, adapting as the network evolves. T This detection method is effective for recognizing new attack methodologies, which signature-based systems may overlook.
- Anomaly detection can promptly identify internal attacks, such as a compromised user account performing unauthorized actions. For example, if an administrative assistant's account is used for system administration, an alert is generated due to the atypical activity.

It is also worth mentioning a set of disadvantages that need to be compensated.

- The initial training period for defining normal activity can span from days to months, presenting challenges as user behaviors frequently evolve.
- Maintaining accurate profiles for diverse user groups can be complex, especially in environments where different roles generate distinct activity patterns.
- while the system is being "trained," the IDS provides no protection, so it's vital no intrusive activity occurs during this training period.
- Some systems allow for dynamic updates to profiles based on ongoing traffic and activity monitoring. However, this feature introduces vulnerabilities, as attackers can exploit it by gradually introducing intrusive activities, thereby training the IDS to disregard them as normal, resulting in false negatives and diminished detection efficacy.
- IDS systems should be continually tuned to strike a balance between false negatives and false positives.

- The last major drawback to anomaly-based detection is its complexity. The adopted strategies are often profile- building strategies that are hard to explain and understand.